
Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

1/25

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"
Deliberation no. 5FR/2023 of July 5, 2023

The National Commission for Data Protection sitting in a restricted formation, composed of Ms. Tine A. Larsen, Chair, and Messrs. Thierry Lallemand and Marc Lemmer, Commissioners;

Considering the regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC;

Considering the law of August 1, 2018 on the organization of the National Commission for Data Protection and the general regime on data protection, notably its Article 41;

Considering the internal regulations of the National Commission for Data Protection adopted by decision no. 3AD/2020 dated January 22, 2020, notably its Article 10.2;

Considering the regulation of the National Commission for Data Protection concerning the investigation procedure adopted by decision no. 4AD/2020 dated January 22, 2020, notably its Article 9;

Considering the following:

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

2/25

I. Facts and Procedure

1. On March 10, 2021, the National Commission for Data Protection (hereinafter: the "CNPD" or the "National Commission") received a complaint from Ms. [...] (hereinafter: "the complainant") regarding the publication of her [data] [on the website] of Company X (hereinafter: "Company X") and reporting to the CNPD potential violations of the provisions of regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (hereinafter: the "GDPR").

2. In the course of the investigation of the complaint, it appeared that Company A [...] had transferred the personal data of the complainant to Company B, which in turn transferred said data to Company X. During its deliberation session on July 1, 2022, the National Commission for Data Protection sitting in plenary formation decided to open an investigation into Companies A, B, and C based on Article 38 of the law of August 1, 2018 on the organization of the National Commission for Data Protection and the general regime on data protection (hereinafter: "law of August 1, 2018") and to appoint Mr. Alain Herrmann as the head of the investigation.

3. The said decision specified that the investigation conducted by the CNPD aimed to verify the application and compliance by the three aforementioned companies "with the provisions of the GDPR, notably those relating to the lawfulness of processing, the obligation to inform the data subject regarding the transfer of their data to third parties, and the right to erasure, in the particular context of the transfer of the complainant's personal data to a third party."

4. Company A is registered in the Luxembourg Trade and Companies Register under number [...] and has its registered office at [...], [...] (hereinafter: the "controlled entity"). It [provides electronic communications services].¹

¹ See Article [...] of its company constitution dated [...] filed on [...].

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

3/25

5. The decision of the National Commission sitting in a restricted formation (hereinafter: the "Restricted Formation") on the outcome of the investigation will be based on:

-

the processing carried out by the controlled entity in the context of the aforementioned complaint and verified by the agents of the CNPD; and

-

the legal and regulatory provisions taken into account by the head of the investigation in his communication of grievances.

6. The controlled entity was informed of the opening of the investigation against it by letter from the head of the investigation dated August 23, 2022. It appears from this letter that the head of the investigation had defined the following control objectives:

“• Determine the legal qualification of the controlled entities in relation to the GDPR in order to know which entity/entities is/are responsible for the processing and/or subcontracting;
• Verify the legality of the transfer of personal data of the complainant by Company A to Company B and/or Company C;
• Verify the legality of the transfer of personal data of the complainant by the entities concerned to Company X;
• Verify compliance by the processor(s) with their obligation to inform the data subject regarding the transfer of personal data to a third party;
• Verify that the processor(s) have complied with the request for erasure and/or the right to object of the data subject.”

7. The letter was accompanied by the document titled “Initial Findings Investigation no. [...]” setting out the initial findings made by the agents of the CNPD based on the documents collected in the context of the complaint and submitted to the present investigation (hereinafter: the “initial findings”). The head of the investigation offered the controlled entity the opportunity to “challenge the facts set out in the initial findings, or to provide [its] possible comments, clarifications or additions” by October 7, 2022, at the latest.

8. The controlled entity responded by letter dated October 7, 2022.

9. At the end of his investigation, the head of the investigation notified the controlled entity on January 25, 2023, of a communication of grievances detailing the breaches he considered to have occurred in this case in relation to the requirements prescribed by Article 13.1.e) of the GDPR (obligation to provide information regarding the recipients or categories of recipients of personal data) and by Article 24.1 of the GDPR (obligation to implement appropriate technical and organizational measures).

The head of the investigation proposed to the Restricted Formation to adopt two different corrective measures, as well as to impose on the controlled entity an administrative fine of 1,500 euros.

The opportunity to submit written observations on the communication of grievances was offered to the controlled entity. The latter did not provide any observations to the head of the investigation.

10. The president of the Restricted Formation informed the controlled entity by letter dated March 13, 2023, that its case would be included in the agenda of the Restricted Formation meeting on April 27, 2023, and that it was offered the possibility to be heard. By email dated April 18, 2023, the controlled entity confirmed its presence at said meeting.

During this meeting, the head of the investigation and the controlled entity, represented by Mr. [...], presented their oral observations in support of their written observations and answered questions posed by the Restricted Formation. The controlled entity had the last word.

II. In law

II.1. On the quality of the controlled entity regarding the processing at issue

1. On the principles

12. In accordance with Article 4 point 7) of the GDPR, the data controller is “the natural or legal person, public authority, service, or other body which, alone or jointly with others, determines the purposes and means of the processing [...]”.

11. Article 4 point 8) of the GDPR defines the processor as “the natural or legal person, public authority, service, or other body which processes personal data on behalf of the data controller.”

12. The European Data Protection Board (hereinafter: the “EDPB”) has provided further explanations in its guidelines on the concepts of data controller and processor, which “play a crucial role in the application of the [GDPR], as they determine who is responsible for compliance with the various rules on data protection and how data subjects can

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

4/25

exercise their rights.”

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

5/25

exercise their rights in practice.” It is specified that these concepts are “functional concepts in that they aim to allocate responsibilities based on the actual roles played by the parties and autonomous concepts in that they must be interpreted primarily according to EU legislation on data protection.” 2

2. In this case

13. In a letter dated October 7, 2022, the controlled entity explained [...] that “the management and administration of Company A are ensured by Company B and Company C in accordance with the collaboration agreement concluded between shareholders on [...] (Annex 1). Indeed, [...] all tasks are distributed between Company B and Company C in accordance with the annex of the aforementioned collaboration agreement (Annex 2).”

14. In the aforementioned letter dated October 7, 2022, the controlled entity further explained that “being a company benefiting from its own clients, [it] is the data controller with respect to them. Company B and Company C are not joint data controllers contrary to what was indicated to you by the employee of Company B and reiterated in document number 9 of the file. Company B and Company C are subcontractors on behalf of Company A as evidenced by the subcontracting agreements concluded by Company A with these two companies (Annex 3 and 4).”

It follows from the same letter that its subcontractor Company B (hereinafter: “Company B” or the “subcontractor”) is responsible for transmitting on its behalf the client files to Company X for publication [on its website].

15. As the complainant subscribed on April 27, 2015, to a subscription contract with the controlled entity, the latter is to be considered as the data controller of the personal data of the complainant in the context of said contract, while Company B acts in this specific context as a subcontractor of the controlled entity with the mission to manage [the client files] in accordance with the aforementioned subcontracting agreement.

16. During the Restricted Formation session on April 27, 2023, the controlled entity confirmed the aforementioned qualities of Company A and Company B, while specifying that the two entities do not have a common client file and that each has its own IT system. Nevertheless, under the subcontracting agreement, personnel from the subcontractor would have access to the IT system of the controlled entity to carry out the necessary operations on its behalf, [...], on the one hand, and to send said file

monthly to Company X (unless there has been no modification compared to the previous month), on the other hand.

II. 2. On the grounds for the decision

A. On the breach related to the obligation to inform the data subjects

1. On the principles

17. Pursuant to Article 12.1 of the GDPR, the “data controller takes appropriate measures to provide any information referred to in Articles 13 and 14 as well as to carry out any communication under Articles 15 to 22 and Article 34 regarding the processing to the data subject in a concise, transparent, comprehensible, easily accessible manner, in clear and plain language, particularly for any information specifically addressed to a child. The information is provided in writing or by other means including, where appropriate, electronically. When the data subject requests it, the information may be provided orally, provided that the identity of the data subject is demonstrated by other means.”

18. Article 13 of the GDPR provides as follows:

“1. When personal data relating to a data subject are collected from that data subject, the data controller shall provide, at the time when the data in question are obtained, all of the following information:

[...]

e) the recipients or categories of recipients of the personal data, if they exist;

[...]

19. In accordance with Article 4 point 9) of the GDPR, “recipient” means the natural or legal person, public authority, service, or any other body which receives communication of personal data, whether or not a third party. [...]”.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

6/25

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

7/25

20. Transparency is a fundamental aspect of the principles relating to the processing of personal data. The obligations in this regard have been clarified by the Article 29 Working Party in its guidelines on transparency under Regulation (EU) 2016/679, the revised version of which was adopted on April 11, 2018 (hereinafter: "WP 260 rev.01" or the "guidelines on transparency").

These guidelines particularly clarify the general transparency rules established by Article 12 of the GDPR, which are applicable to the communication of information to data subjects (Articles 13 and 14 of the GDPR), to communications addressed to data subjects regarding the exercise of their rights (Articles 15 to 22 of the GDPR), and to communications concerning data breaches (Article 34 of the GDPR).

21. It should be noted that the EDPB, which succeeded the Article 29 Working Party on May 25, 2018, has adopted and reaffirmed the documents adopted by said Working Party between May 25, 2016, and May 25, 2018, including the aforementioned guidelines on transparency.

2. In this case

22. By letter dated October 7, 2022, the controlled entity sent the head of the investigation the "general conditions of Company A currently in force. You can see that these indeed mention the data processing carried out by Company B and Company C in the context of subcontracting (Annex 5)."

23. In a letter dated November 11, 2022, the head of the investigation nevertheless considered that these general conditions were created only "recently since, on the one hand, the URL link allowing access contains the date of [...] 2022 and, on the other hand, the metadata of the 'pdf' document mentions the creation date as [...] October 2022 (see annex)."

He therefore requested in said letter that the controlled entity indicate "whether such an information document was available on the site [...] at the date of the signing of the subscription contract of Company A by Ms. [...] [on April 27, 2015]. If the answer is positive, please send us the version of this information document as available on the site [...] on that same date."

4 See in particular Articles 5.1.a) and 12 of the GDPR, see also recitals (39), (58) to (60) of the GDPR.

5 WP 260 rev.01, point 7.

6 See EDPB decision Endorsement 1/2018 of May 25, 2018, available at:

https://edpb.europa.eu/sites/edpb/files/files/news/endorsement_of_wp29_documents_en_0.pdf.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

8/25

24. By letter dated November 28, 2022, the controlled entity sent the signed contract of the complainant dated April 27, 2015, along with a form accepting the general conditions then in force. However, it indicated that at the time of signing the contracts, the general conditions signed by the clients would not have been systematically retained, and therefore sent the general conditions signed by another client dated September 14, 2014, while specifying that the general conditions would not have changed between that date and the date of signing the complainant's contract.

25. In the statement of objections dated January 25, 2023, the head of the investigation noted that "according to the controlled entity, the Complainant signed, at the same time as her subscription contract, the general conditions of the services of Company A then in force (DOCUMENT 2)."

26. He also noted that the controlled entity concluded a subcontracting contract with its subcontractor Company B on [...] 2017, which was subject to an amendment dated [...] 2018 and which provides for the transfer of subscriber data from the controlled entity to said subcontractor. He concluded that "the information that Company B is the recipient of the personal data of the subscribers of Company A should therefore be included in the information provided by the Controlled Entity to the data subjects since the signing of said subcontracting contract, in accordance with Article 26, paragraph 1, letter (c) of the amended law of August 2, 2002, relating to the protection of individuals with regard to the processing of personal data, and then in accordance with the GDPR from May 25, 2018."

27. Furthermore, the head of the investigation noted that "the general conditions of the services of Company A, made available to the data subjects on the website [...], have not been updated following the signing by the Controlled Entity of the subcontracting contract with Company B, nor following the entry into force of the GDPR.

Indeed, as shown by the screenshot [...], the general conditions of Company A available on the website [...] are the same between [...] 2014 and [...] 2022 (DOCUMENT 4).

Moreover, the Controlled Entity transmitted to the agents of the CNPD in charge of the investigation the general conditions of Company A as available on the website [...] as of [...] October 2022 (DOCUMENT 5). These general conditions indeed specify that the

7 Statement of objections, point 21.

8 Statement of objections, points 22 to 23.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

9/25

personal data of the subscribers of Company A are transferred to Company B. However, these general terms and conditions were made available to the concerned individuals on the website [...] on [...] October 2022, as shown by the screenshot of the metadata from the website [...] (EXHIBIT 6), that is, after the opening of the present investigation.

28. Thus, the investigator concluded that "the conditions of Article 13, paragraph 1, letter e) of the GDPR have not been respected, as the Controller did not update the information made available to the Complainant regarding the recipients of their personal data, via its website [...] or by any other means."

29. The Restricted Formation recalls that, even though the right to information of the data subject was already enshrined in the repealed law of August 2, 2002, relating to the protection of individuals with regard to the processing of personal data, at least since May 25, 2018, the controller should have informed the complainant, among other things, about the recipients or categories of recipients of the personal data.

30. It first notes that the complainant entered into a subscription contract with the controller on April 27, 2015, that is, before the GDPR came into effect, and which ended after the GDPR came into effect, specifically on June 30, 2019.

31. Similarly, the Restricted Formation observes that the general terms and conditions that the complainant allegedly signed on April 25, 2015, at the same time as their subscription contract, do not mention any transfer of data to a subcontractor, while the general terms and conditions provided by the controller to the investigator on [...] October 2022 contain a specific point on subcontracting in the broader section concerning data processing.

9 Communication of grievances, point 24.

10 Communication of grievances, point 25.

11 This law, which was repealed by the law of August 1, 2018, provided in its Article 26.1 c), first indent the right to information of the data subject regarding "the recipients or categories of recipients to whom the data may be communicated."

12 Date of the entry into force of the GDPR.

13 See annex 3 of the controller's letter of November 28, 2022.

14 See the section [...].

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

10/25

32. It also notes that according to the investigator, these latest general terms and conditions were made available to customers only on [...] October 2022.

33. During the Restricted Formation session on April 27, 2023, the controller indicated that updates to the general terms and conditions had been made frequently, but that it had not kept a history of the different versions. It also formally contested that this mention of subcontracting was only inserted in 2022, while admitting that it does not have a version of the general terms and conditions existing between 2015 and 2022 and thus has no proof of when this update incorporating subcontracting actually took place.

34. Thus, the Restricted Formation finds that it has obtained no documentation containing proof that the controller updated its general terms and conditions after the entry into force of the GDPR and before October 2022. It must conclude that it has no evidence that the complainant received information from the controller regarding the recipients of their personal data, via its website [...] or by any other means, after the entry into force of the GDPR and until the termination of their subscription contract in June 2019, or even until the last transmission of their personal data to Company B in February 2022. Furthermore, it also lacks evidence that other customers of the controller were informed about the recipients of their personal data, and more specifically about the transfer of their data to the subcontractor [...], after the entry into force of the GDPR and until October 2022.

35. In light of the above, the Restricted Formation aligns with the investigator and concludes that at the beginning of the investigation, the controller failed to meet its obligation arising from Article 13.1. e) of the GDPR.

36. Regarding the measures taken by the controller after the beginning of the investigation, the Restricted Formation will return to this in point 62, as well as in Chapter II.3. Section 2.2. of this decision.

15 See communication of grievances, point 24 and point 27 of this decision.

16 That is, at the time of receipt of the letter from the investigator informing the controller of the opening of the investigation against it on August 23, 2022.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

11/25

B. On the breach related to the obligation to implement appropriate technical and organizational measures in accordance with Article 24 of the GDPR

1. On the principles

37. According to Article 5.2 of the GDPR, the "data controller is responsible for compliance with paragraph 1 and is able to demonstrate that it is complied with (accountability)."

38. Article 24 of the GDPR, titled "Responsibility of the data controller," provides in its first paragraph that "[t]aking into account the nature, scope, context, and purposes of the processing as well as the risks, varying in probability and severity, to the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure and to be able to demonstrate that the processing is performed in accordance with this Regulation. These measures shall be reviewed and updated as necessary."

2. In this case

39. The subscription contract concluded on April 27, 2015, between the controlled entity and the complainant ended on June 30, 2019.

40. However, it appears from the initial findings that in October 2020, following a telephone prospecting call for religious purposes, the complainant realized that her [data] was published [...] on the website of Company X and that said [data] had been transferred by Company B on behalf of the controlled entity to Company X for publication [on its site]. On October 19, 2020, Company X confirmed to the complainant that her data would be removed from its website.

41. However, on March 10, 2021, the complainant's [data] was again available on the website of Company X, which stated that said [data] had once again been transferred to it by Company B for publication [on its site].

42. In a letter dated June 1, 2021, the subcontractor [...] specified that Company X had contacted its services on March 29, 2021, to inform them of the complainant's wish not to appear [on its site], on the one hand, and that since the complainant had not been a subscriber with the controlled entity since June 30, 2019, "her [data] should not have been transferred to Company X [in] 2021. This transfer resulted from an internal configuration error and corrective measures have been taken to remedy it."

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

12/25

43. However, following another telephone prospecting call for religious purposes made to the complainant on March 5, 2022, it appeared that her [data] had again been published [on the site] of Company X, which claimed that this publication occurred following a transfer of said [data] by Company B to Company X in February 2022.

44. In a letter dated October 7, 2022, the controlled entity acknowledged "a malfunction caused by human error in the file transmission to Company X by one of our subcontractors, namely Company B. Indeed, the data concerning Mrs. [...] should not have been transmitted to Company X as her contract had been terminated. We also acknowledge an abnormally long processing time for Company X's request to remove lists concerning Mrs. [...]. As the Data Controller, we understand that these faults are attributable to Company A. Indeed, Company A should have ensured the legality of the data transfer to Company X by its subcontractors."

45. In the same letter, the controlled entity also formally contested having transferred the complainant's data to Company X again in February 2022 and insisted that according to "the information in our possession, the data of Mrs. [...] was removed from the lists transmitted to Company X on [March 29, 2022]¹⁷ and has not been transmitted to Company X thereafter."

46. In the communication of grievances dated January 25, 2023, the head of the investigation noted that Company X received the complainant's data from Company B to feature it [on its site] in 2020 and 2021, while "[t]he subscription of Company A of the Complainant ended on June 30, 2019, from which date Company B, as a subcontractor of the Controlled entity, should have ceased transferring the personal data of the Complainant to Company X."¹⁸

47. Furthermore, he noted that the personal data of the complainant was again present in the file containing the data of subscribers of Company A as transmitted in February 2022 to Company X, even though Company B assured in its letter dated October 7, 2022, that the complainant's data had not been transmitted to Company X since March 29, 2021. Similarly, he was of the opinion that a "simple search action 'Ctrl+f' in the file [...] as transmitted by Company B to Company X on March 23, 2022, nevertheless allows one to see that the complainant's data is indeed present."

17 The Restricted Formation assumes that this refers to March 29, 2021.

18 Communication of grievances, point 28.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

13/25

present among the subscriber data of Company A to be included [on the site] of Company X.¹⁹

48. Thus, the head of the investigation concluded that "as the data controller, the Controlled has not demonstrated the implementation of any technical and organizational measures allowing it to verify compliance with the provisions of the GDPR by its subcontractor. Indeed, the Controlled does not carry out any regular checks of its subcontractor and responded to the Initial Findings of this investigation without taking the trouble to perform a simple "Ctrl+f" check in the files [...] of Company B." For these reasons, it was of the opinion "that the conditions of Article 24, paragraph 1, of the GDPR have not been met, the Controlled having failed to implement appropriate technical and organizational measures so that the processing of the Claimant's data complies with the requirements of the GDPR and ensures the protection of the rights of the data subject."²⁰

49. The Restricted Formation wishes to remind that Article 24.1 of the GDPR obliges each data controller to take appropriate technical and organizational measures to ensure and be able to demonstrate that processing is carried out in accordance with the GDPR. This article reflects the principle of "accountability" as stated in Article 5.2 of the GDPR, according to which "the data controller is responsible for compliance with paragraph 1 (accountability) and is able to demonstrate it."

Furthermore, according to Recital (74) of the GDPR, "the responsibility of the data controller should be established for any processing of personal data that it carries out itself or that is

carried out on its behalf. [...]”, that is to say, carried out by one of its subcontractors.

50. It notes in this context that since June 30, 2019, the date of termination by the claimant of the subscription contract concluded with the Controlled, the claimant should no longer have appeared on the list of subscribers wishing to appear [on the website] that Company B transmits monthly on behalf of the Controlled to Company X. However, the subcontractor transmitted the [data] of the claimant precisely for the purpose of publication [on its site] in 2020, in 2021, as well as in February 2022. Indeed, Company B sent on December 14, 2022, among other things, the email and the file [...] sent on February 15, 2022, to Company X containing the [data] of the subscribers of Company A wishing to appear [on the site] of Company X, including still those of the claimant.

51. It also takes into account the letter dated October 7, 2022, in which the Controlled acknowledged "a malfunction caused by human error in the transmission of the file to Company X by one of our subcontractors, namely Company B. Indeed, the data concerning Mrs. [...] should not have been transmitted to Company X as her contract had been terminated. [...]. As the Data Controller, we understand that these faults are attributable to Company A. Indeed, Company A should have ensured the lawfulness of the transfer of data to Company X by its subcontractors."

52. During the session of the Restricted Formation on April 27, 2023, the Controlled also confirmed that, contrary to previous assertions, the [data] of the claimant were indeed still included in the file transmitted in February 2022 to Company X. It explained that these irregular transmissions were related to an internal IT problem, as at the time when the claimant's subscription with Company A was terminated in 2019, the registration in the file of persons wishing to appear [on the website] of Company X was not automatically deleted. According to the Controlled, this update in the IT system of Company A [...] would not have been made until March 2022.

53. Regardless of the reasons that led to these irregular transmissions of the claimant's [data] to Company X by the Controlled's subcontractor in 2020, in 2021, as well as in February 2022, the Restricted Formation notes that the requests for deletion of the claimant's data by Company X dated October 19, 2020, and March 29, 2021, should have already led the Controlled to conduct investigations into the technical and organizational measures implemented internally, as well as with its subcontractor.

54. However, as the [data] of the claimant were once again transferred by its subcontractor to Company X on February 15, 2022, it appears that the Controlled did not carry out regular checks of the technical and organizational measures implemented by its subcontractor. It even stated in its letter dated October 7, 2022, that the claimant's data had been removed from the lists transmitted to Company X on March 29, 2021, and had not been transmitted thereafter. Nevertheless, a search for the name of the claimant in the file transmitted by its subcontractor to Company X in February 2022, notably using the keyboard shortcut "Ctrl+f," would have revealed that the [data] of the claimant were still present in said file.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

15/25

55. In light of the above, the Restricted Formation agrees with the opinion of the head of the investigation and concludes that at the beginning of the investigation, the entity under scrutiny did not implement appropriate technical and organizational measures to verify compliance with the provisions of the GDPR by its subcontractor. It therefore failed to meet its obligation under Article 24.1 of the GDPR.

II. 3. On the fine and corrective measures

1. On the principles

56. In accordance with Article 12 of the law of August 1, 2018, the National Commission has the powers provided for in Article 58.2 of the GDPR:

- “a) to warn a data controller or a processor that the intended processing operations are likely to violate the provisions of this regulation;
- b) to reprimand a data controller or a processor when the processing operations have resulted in a violation of the provisions of this regulation;
- c) to order the data controller or processor to comply with requests made by the data subject to exercise their rights under this regulation;
- d) to order the data controller or processor to bring the processing operations into compliance with the provisions of this regulation, where appropriate, in a specific manner and within a specified timeframe;
- e) to order the data controller to notify the data subject of a personal data breach;
- f) to impose a temporary or definitive limitation, including a ban, on processing;
- g) to order the rectification or erasure of personal data or the restriction of processing in accordance with Articles 16, 17, and 18 and the notification of these measures to the recipients to whom the personal data have been disclosed in accordance with Article 17, paragraph 2, and Article 19;
- h) to withdraw a certification or order the certification body to withdraw a certification issued under Articles 42 and 43, or to order the certification body not to issue a certification if the applicable requirements for certification are not or are no longer met;

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

16/25

- i) to impose an administrative fine in accordance with Article 83, in addition to or instead of the measures referred to in this paragraph, depending on the specific characteristics of each case;
- j) to order the suspension of data flows addressed to a recipient located in a third country or to an international organization.”

57. In accordance with Article 48 of the law of August 1, 2018, the CNPD may impose administrative fines as provided for in Article 83 of the GDPR, except against the State or municipalities.

58. Article 83.1 of the GDPR provides that each supervisory authority ensures that the administrative fines imposed are, in each case, effective, proportionate, and dissuasive.

59. Article 83.2 specifies the elements that must be taken into account to decide whether to impose an administrative fine and to determine the amount of that fine:

- “a) the nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing concerned, as well as the number of affected data subjects and the level of damage they have suffered;
- b) whether the violation was committed intentionally or negligently;
- c) any measures taken by the data controller or processor to mitigate the damage suffered by the data subjects;
- d) the degree of responsibility of the data controller or processor, taking into account the technical and organizational measures they have implemented under Articles 25 and 32;
- e) any relevant previous violations committed by the data controller or processor;
- f) the degree of cooperation established with the supervisory authority in order to remedy the violation and mitigate any possible negative effects;
- g) the categories of personal data concerned by the violation;

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

17/25

- h) the manner in which the supervisory authority became aware of the violation, including whether, and to what extent, the data controller or the processor notified the violation;

- i) when measures referred to in Article 58(2) have previously been ordered against the data controller or the relevant processor for the same matter, compliance with those measures;
- j) the application of approved codes of conduct pursuant to Article 40 or approved certification mechanisms pursuant to Article 42; and
- k) any other aggravating or mitigating circumstances applicable to the circumstances of the case, such as financial benefits obtained or losses avoided, directly or indirectly, as a result of the violation."

60. The imposition of administrative fines has been clarified by the Article 29 Working Party in its "Guidelines on the application and setting of administrative fines for the purposes of Regulation (EU) 2016/679" adopted on October 3, 2017. These guidelines have been reiterated and reapproved by the EDPB.²¹ The Restricted Formation emphasizes that these guidelines have been supplemented by the "Guidelines 04/2022 on the calculation of administrative fines under the GDPR" of the EDPB, the 2.0 version of which was adopted on May 24, 2023.²²

61. The Restricted Formation wishes to clarify that the facts taken into account in this decision are those established at the beginning of the investigation. Any subsequent changes regarding the data processing subject to the investigation, even if they allow for full or partial compliance to be established, do not retroactively annul a confirmed breach.

62. Nevertheless, the steps taken by the controller to comply with the GDPR during the course of the investigation procedure or to remedy the breaches identified by the head of the investigation in the communication of grievances are taken into account by the Restricted Formation in the context of any corrective measures to be imposed and/or the determination of the amount of any potential administrative fine to be imposed.

21 See decision Endorsement 1/2018 of the EDPB of May 25, 2018, available at:

https://edpb.europa.eu/sites/edpb/files/files/news/endorsement_of_wp29_documents_en_0.pdf.

22 The guidelines on the calculation of fines are currently only available in English.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with company "A"

18/25

2. In this case

2.1 Regarding the imposition of an administrative fine

63. In the communication of grievances, the head of the investigation proposed to the Restricted Formation

to impose an administrative fine of 1,500 euros against the controller.²³

2.1.1 On the appropriateness of imposing an administrative fine

64. In order to decide whether to impose an administrative fine, the Restricted Formation analyzes the criteria set out in Article 83(2) of the GDPR.

65. Regarding the nature and severity of the violation (Article 83(2)(a) of the GDPR), it recalls that the obligation to provide information on the processing of personal data is an essential duty of data controllers, so that individuals are fully aware of how their personal data will be used once collected. A breach of this article of the GDPR thus constitutes an infringement of the rights of the data subjects. The right to information has moreover been strengthened under the GDPR, which reflects its particular importance.

Regarding the breach of Article 24 of the GDPR, the Restricted Formation wishes to emphasize that the principle of "accountability" as stated in Article 5(2) of the GDPR and elaborated in Article 24 is also at the heart of the GDPR and reflects the paradigm shift brought about by the GDPR, namely the transition from a regime based on notifications and prior authorizations by the CNPD to greater accountability and responsibility of the data controller.

Furthermore, as the head of the investigation pointed out, such a breach of Article 24 of the GDPR "renders the legislation on the protection of personal data ineffective as long as the data controller does not ensure that all data transmitted to its processor is processed in compliance with the

GDPR."24

66. Regarding the duration criterion (Article 83(2)(a) of the GDPR), the Restricted Formation notes that the breach of the information obligation has persisted over time, at least since the

23 Communication of grievances, points 47 to 56 and 58.

24 Communication of grievances, point 47.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

19/25

implementation of the GDPR and until October 2022, the document titled "GENERAL TERMS OF SERVICE of Company A" sent by the controller to the head of the investigation on [...] October 2022 and available on the controller's website contained a specific point on subcontracting in the broader section concerning data processing.

Indeed, as mentioned in point 34, it has no documentation containing evidence that the controller updated its general terms after the implementation of the GDPR and before October 2022 by including information on the recipients of personal data, and more specifically on the transfer of data to its subcontractor Company B.

Regarding the implementation of measures to ensure that its subcontractor complies with the GDPR in accordance with Article 24 of the GDPR, particularly to verify that this subcontractor ceases to transfer the personal data of the complainant to Company X, the controller confirmed during the Restricted Formation session on April 27, 2023, that the irregular transmissions of the complainant's [data] to Company X were linked to an internal IT problem and that this update in the IT system of Company A [...] would have been made in March 2022. However, no documentation submitted to the Restricted Formation contains evidence attesting that the controller has now implemented appropriate technical and organizational measures to prevent its subcontractor from transferring the complainant's data to Company X, so that the violation has therefore lasted at least since the termination of the complainant's contract on June 30, 2019, from which date Company B, as a subcontractor of the controller, should have ceased transferring the complainant's personal data to Company X, at least until February 2022.

67. Regarding the number of affected individuals and the level of damage they have suffered (Article 83.2 a) of the GDPR), the Restricted Formation notes concerning the failure to inform the affected individuals that the complainant was not aware that her personal data processed under her subscription with Company A had been transferred since 2017 to Company B as a subcontractor of the controller. She agrees with the head of the investigation in that "this lack of information resulted in the complainant first contacting a third party to the present investigation and taking time to understand which entities were responsible for the transfer of her personal data to Company X in order to have her [data on the site] of Company X. Furthermore, this lack of information

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

20/25

concerns all individuals who have or have had a subscription with Company A since the Controller entered into a subcontracting agreement with Company B."

As of December 31, 2018, the number of subscribers of Company A was [...] individuals, while it had

decreased to [...] by December 31, 2022. The Restricted Formation is therefore of the opinion that all these clients are individuals affected by the violation of Article 13 of the GDPR.

Regarding the failure of a data controller to implement appropriate technical and organizational measures allowing them to verify compliance with the provisions of the GDPR by their subcontractor, the complainant is the only person known to the CNPD as having been affected by the violations of the GDPR by the controller.

68. Regarding the question of whether the violations were committed intentionally or negligently (Article 83.2.b) of the GDPR), the Restricted Formation recalls that "intention," meaning an offense committed deliberately, encompasses both knowledge and will in relation to the characteristics of an offense, while "non-intentionally" (by negligence) means that there was no intention to commit the violation, although the data controller or the subcontractor did not comply with the duty of care imposed on them by law.

The Restricted Formation notes in this case that it has no evidence attesting that the controller updated its general terms after the implementation of the GDPR and before October 2022 by including information on the recipients of personal data. Furthermore, irregular transmissions of the complainant's data by the controller's subcontractor to Company X for publication [on its site] occurred in 2020, 2021, and February 2022.

While the Restricted Formation is of the opinion that the facts and violations observed do not reflect an intentional breach of the GDPR by the controller, it nevertheless considers that the violations were committed negligently.

69. Regarding the measures taken by the controller to mitigate the damage suffered by the affected individuals (Article 83.2.c) of the GDPR), the Restricted Formation takes into account the

25 Communication of grievances, point 49

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

21/25

measures taken by the controller and refers to Chapter II.3, Section 2.2 of this decision for related explanations.

70. It also notes that while several measures have been implemented by the controller to remedy, in whole or in part, certain breaches, these were only adopted following the initiation of the investigation by the CNPD agents on August 23, 2022 26 (see also point 61 of this decision).

71. Regarding the degree of cooperation established with the supervisory authority (Article 83.2.f of the GDPR), the Restricted Formation takes into account the statement of the head of the investigation that the controller has shown good cooperation with the CNPD agents in charge of the investigation.

72. As for the categories of personal data concerned by the breach (Article 83.2.g of the GDPR), these are [the data] of the complainant unlawfully transferred multiple times by the controller's subcontractor to Company X to appear [on its website].

73. Regarding how the CNPD became aware of the breach (Article 83.2.h of the GDPR), the CNPD was informed of the facts constituting the breach as part of the complaint filed by the complainant.

74. The Restricted Formation finds that the other criteria of Article 83.2 of the GDPR are neither relevant nor likely to influence its decision regarding the imposition of an administrative fine and its amount.

75. Therefore, the Restricted Formation considers that the imposition of an administrative fine is justified in light of the criteria set out in Article 83.2 of the GDPR for breaches of Articles 13.1.e) and 24.1 of the GDPR.

2.1.2. On the amount of the fine

76. The controller is a company [...]. It indicated that it had achieved a net turnover of [...] euros and a net profit of [...] euros for the year 2021.27 During the Restricted Formation session on April 27, 2023, the controller specified that the annual accounts for 2022 have not yet been finalized.

26 Sending of the opening of the investigation with the initial findings.

27 See the letter dated October 7, 2022, in which the controller stated the following [...].

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

22/25

[...].²⁸ As of December 31, 2018, the number of subscribers of Company A was [...] persons, while it was only [...] as of December 31, 2022.²⁹

77. Regarding the amount of the administrative fine, the Restricted Formation recalls that Article 83.3 of the GDPR provides that in the case of multiple violations, as is the case here, the total amount of the fine cannot exceed the maximum amount set for the most serious violation. Since a breach of Articles 13.1.e) and 24.1 of the GDPR is attributed to the controller, the maximum amount of the fine that can be imposed is 20 million euros or 4% of the total annual global turnover, with the higher amount being retained, in accordance with Article 83.5 of the GDPR.

78. In light of the controller's responsibility, its financial capabilities, and the relevant criteria of Article 83.2 of the GDPR mentioned above in the section "2.1.1 On the appropriateness of imposing an administrative fine," the Restricted Formation considers that the imposition of a fine of one thousand five hundred (1,500) euros appears both effective, proportionate, and deterrent, in accordance with the requirements of Article 83.1 of the GDPR.

2.2 Regarding the implementation of corrective measures

79. In the communication of grievances³⁰ the head of the investigation "proposes to the Restricted Formation to take the following corrective measures, within a period of 1 month from the notification to the Controller of the decision made by the Restricted Formation:

- " - Remind the data controller of their obligation to inform the data subjects, in accordance with Article 13 of the GDPR;
- Order the data controller to implement measures to ensure that their subcontractor complies with the GDPR, particularly to verify that this subcontractor ceases to transfer the personal data of the Complainant to Company X."

80. Regarding the corrective measures proposed by the head of the investigation and by reference to point 62 of this decision, the Restricted Formation takes into account the steps taken by the controller to comply with the provisions of Articles 13.1.e) and 24.1 of the GDPR, as detailed in its letters of October 7, 2022, and November 28, 2022. More specifically, it notes the following facts:

28 Letter from the controller to the CNPD dated November 28, 2022.

29 Letter from the controller to the CNPD dated January 11, 2022.

30 Communication of grievances, points 42 to 45 and 54.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

23/25

- Regarding the corrective measure proposed by the head of the investigation mentioned in the first bullet point of paragraph 79 of this decision concerning the reprimand of the data controller regarding its obligation to inform the data subjects, in accordance with Article 13 of the GDPR, the controlled entity sent by mail on October 7, 2022, the current general terms and conditions of Company A.

In the statement of objections, the head of the investigation noted that "[n]ow, in the general terms and conditions of sale of the services of Company A, there is information stating that the personal data of the subscribers of Company A are transferred to Company B." The Restricted Formation indeed observes that the document titled "GENERAL TERMS AND CONDITIONS OF SERVICES of Company A" sent by the controlled entity to the head of the investigation on [...] October 2022 and available on the controlled entity's website contains a specific point on subcontracting within the broader section concerning data processing. Nevertheless, as mentioned in paragraph 34, it does not

have any documentation containing proof that the controlled entity updated its general terms and conditions after the GDPR came into effect and before October 2022 by including information on the recipients of personal data, and more specifically on the transfer of data to its subcontractor Company B. On the other hand, since at least [...] October 2022, the subscribers of the controlled entity have been informed on this point. For these reasons, the Restricted Formation believes that it is appropriate to impose the corrective measure proposed by the head of the investigation in this regard and mentioned in the first bullet point of paragraph 79 of this decision and to reprimand the controlled entity for violating Article 13.1. e) of the GDPR.

- Regarding the corrective measure proposed by the head of the investigation mentioned in the second bullet point of paragraph 79 of this decision concerning the implementation of measures to ensure that its subcontractor complies with the GDPR, particularly to verify that this subcontractor ceases to transfer the personal data of the complainant to Company X, the controlled entity confirmed during the session of the Restricted Formation on April 27, 2023, that the irregular transmissions of the complainant's [data] to Company X were linked to an internal IT problem, as at the time when the complainant's subscription with Company A was terminated in 2019, the registration in the customer file [...] was not automatically deleted. According to the controlled entity, this update in the IT system of Company A [...] would not have been made until March 2022.

However, no documentation submitted to the Restricted Formation contains proof that the controlled entity has now implemented appropriate technical and organizational measures allowing it to verify compliance with the provisions of the GDPR by its subcontractor to prevent it from transferring the complainant's data to Company X again. In consideration of the insufficient compliance measures taken by the controlled entity in this case and paragraph 62 of this decision, the Restricted Formation therefore believes that it is appropriate to impose the corrective measure proposed by the head of the investigation in this regard and mentioned in the second bullet point of paragraph 79 of this decision.

In light of the preceding developments, the National Commission sitting in a restricted formation, after deliberation, decides:

- to retain the violations of Articles 13.1. e) and 24.1 of the GDPR;
- to impose an administrative fine of one thousand five hundred (1,500) euros against "Company A" for the violations of Articles 13.1. e) and 24.1 of the GDPR;
- to issue an injunction against "Company A" to bring its processing into compliance with the obligations arising from Article 24.1 of the GDPR, within two months following the notification of the decision of the Restricted Formation, and, in particular, to implement appropriate technical and organizational measures allowing it to verify that its subcontractor Company B ceases to transfer the personal data of the complainant to Company X;
- to reprimand "Company A" for violating Article 13.1. e) of the GDPR.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "A"

25/25

Belvaux, July 5, 2023.

The National Commission for Data Protection sitting in a restricted formation

Tine A. Larsen Thierry Lallemand

Marc Lemmer

President

Commissioner

Commissioner

Indication of appeal routes

This administrative decision may be subject to an appeal for reform within three months following its

notification. This appeal must be brought before the administrative court and must necessarily be introduced through a lawyer at the Court of one of the Bar Associations.